Tridium (Niagara Framework) Firmware Attack Surface & Detection Brief

Tridium (Niagara Framework) Firmware Attack Surface & Detection Brief

Scope: CVE and public-advisory research only — firmware has not yet been acquired or extracted (Niagara Central requires a partner login this project does not have). No direct binary examination; findings below are from public vulnerability disclosures, vendor (Honeywell/Tridium) PSIRT advisories, CISA ICS advisories, and third-party research (Nozomi Networks, runZero, Tenable). Do not read this brief as firmware-verified — treat every "affected version" line as vendor-claimed until a real JACE-8000/9000 or Niagara-4-Framework image is pulled and checked against it.

Why Tridium, why now: A fresh cross-reference against the ARNG's full nationwide OT device census (5,723 OT & Building Systems devices, ForeScout + Dragos exports) found **"Tridium, Inc." as the 3rd-largest OT vendor by device count — 480 devices** (OUI-derived vendor string). None of the 14 existing firmware briefs in this folder cover Tridium. The existing briefs skew toward industrial-process-control vendors (Rockwell, SEL, Siemens PLCs) that are a small fraction of this specific inventory; the real population here is dominated by building-automation / physical-security vendors like this one. This brief closes that gap.

Purdue layer mapping: JACE-8000 / JACE-9000 controllers are field-level BAS/BMS supervisory controllers — they sit at **Purdue L2 (Area Supervisory)** when running the local HMI/Px web graphics console that operators view directly, and at **Purdue L3 (Site Operations)** when acting as the Niagara Station/Supervisor aggregating multiple JACEs and brokering north to a campus BMS head-end (the same dual-role pattern the purdue-l3-site-operations-brief.md and purdue-l2-area-supervisory-brief.md docs describe for Honeywell Experion Station/Server — read those two first). Niagara's own architecture reinforces this: a JACE is simultaneously a field controller (BACnet/Modbus/LON talking down to L1 field devices) and a Niagara Station (Fox protocol talking up to a Supervisor or another JACE), so a single JACE-8000 can be the L2/L3 boundary device for a building. No dedicated Purdue L2/L3 cross-reference doc currently lists Tridium among its contributing vendors (both docs list only process-control/DCS vendors) — this brief is written so a future revision of those two docs can add Tridium's Group A (JACE controllers) as a new row.

Architecture / product grouping

Group	Purdue layer	Products	Stack	Research depth
A. JACE field controllers	L2/L3 boundary (field controller + Niagara Station)	JACE-8000, JACE-9000, legacy JACE 3e/6e/7, JACE-700	QNX RTOS (older) / embedded Linux (newer JACE-9000), Niagara runtime, BACnet/IP + Modbus + LON field-side, Fox protocol (TCP/1911, TLS 4911) station-side, Niagara web UI (jxBrowser-embedded Chromium)	CVE/advisory research only — no binary pulled

Group	Purdue layer	Products	Stack	Research depth
B. Niagara Framework (software)	Cross-layer — runs identically on JACE, Supervisor PCs (Windows/Linux), and Niagara Cloud	Niagara AX (legacy, still widely deployed, EOL), Niagara 4.x, Niagara Enterprise Security	Java-based platform + QNX/Windows/Linux host OS, Fox protocol, BACnet/IP, SOAP/HTTP web UI, JRE/Bouncy Castle/libwebp/jxBrowser third-party components	CVE/advisory research only
C. Niagara Edge 10	L1/L2 — small-footprint edge controller	Niagara Edge 10	Same Niagara runtime, smaller field-point count	CVE/advisory research only; fewer dedicated advisories found, mostly covered by the same framework-wide bulletins as JACE-8000

Niagara's single-codebase model means almost every CVE against "the framework" is version-gated, not product-gated — a JACE-8000, a Windows Supervisor, and Niagara Edge 10 can all carry the identical vulnerable Niagara build. That is the single biggest fact that should drive triage of this vendor in the census: **you cannot assume a device is safe because it's "just an edge controller"** — if it runs Niagara 4.10u10 or earlier, it is potentially one of the ten 2025 Nozomi findings regardless of form factor.

Confirmed CVEs / advisories

All entries below were verified against CISA ICS-CERT, Honeywell/Tridium PSIRT bulletins, NVD, or named third-party research during this research pass.

CVE / Advisory	CVSS	Product	Vector	Notes
CVE-2012-4027, CVE-2012-4028, CVE-2012-3025, CVE-2012-3024 (ICSA-12-228-01A)	up to 7.8 (v2)	Niagara AX Framework, all known versions (2012)	Directory traversal + insufficiently protected credential storage in `config.bog` + cleartext Base64 session cookie + predictable session IDs	The original Billy Rios/Terry McCorkle *Washington Post*-covered finding; public PoC existed. Foundational "Niagara stores creds badly, sessions are guessable" bug class.
CVE-2012-4701 (ICSA-13-045-01)	8.5 (v2)	NiagaraAX, all versions	Path traversal via web interface (TCP/80); exploitable with valid creds or if guest access enabled	Separate follow-on from the 2012 cluster; patched in 3.5/3.6/3.7.
CVE-2017-16744, CVE-2017-16748 (ICSA-18-191-03)	6.6 / 7.4 (v3)	Niagara AX 3.8 and prior, Niagara 4 4.4 and prior (Windows)	Path traversal (admin creds required) + **local login using a disabled account name with a**	The blank-password-on-disabled-account bug is independently scored 9.8 by NVD/Tenable (network-exploitable assumption) vs.

CVE / Advisory	CVSS	Product	Vector	Notes
			blank password → administrator access	CISA's 7.4 (local-only assumption) — worth re-validating the access vector once real firmware/config is in hand. Fixed in AX 3.8 Update 4 / Niagara 4.4 Update 1.
CVE-2018-18985 (ICSA-18-333-02)	5.7	Niagara Enterprise Security 2.3u1, Niagara AX 3.8u4, Niagara 4 4.4u2/4.6	Authenticated reflected/stored XSS (CWE-79) in web UI	Fixed across all four product/version lines listed.
CVE-2019-8998, CVE-2019-13528 (ICSA-19-262-01)	7.8 / 4.4	Niagara AX 3.8u4, Niagara 4.4u3, Niagara 4.7u1 — **explicitly includes JACE-8000 and Edge 10**	QNX `procfs` info exposure across process address spaces + improper authorization letting a local utility read privileged files	Local-only, but directly names JACE-8000. Windows/Linux Supervisor installs **not** affected.
CVE-2019-5786 (Honeywell "Niagara Chromium Vulnerability", 2019-05-09)	High	Niagara 4.4u2, 4.6, 4.7 (jxBrowser-embedded Chromium web UI)	Chromium FileReader use-after-free — this was an actively-exploited-in-the-wild Chromium 0-day (Google TAG) before Tridium's bundled Chromium caught up	Supply-chain exposure: Niagara's web UI rides on a Chromium build that lags upstream patches.
CVE-2020-14483 (ICSA-20-224-03)	4.3	Niagara 4.6/4.7/4.8, Niagara Enterprise Security 2.4/4.8	TLS handshake without timeout (CWE-1088) → thread hang, manual restart required	DoS only; fixed in Niagara 4.9.0.198 / EntSec 4.9.0.60.
ICSA-20-168-01 (Ripple20 / Treck TCP/IP stack) — Honeywell "no impact" bulletin (2020-06-30)	n/a	Niagara JACE-8000, Edge 10 (evaluated, not affected)	Treck stack vulnerabilities	Explicitly named JACE-8000/Edge10 as evaluated-and-cleared, not vulnerable — included here because it is one of the few advisories that confirms which Niagara builds do/don't embed Treck.
CVE-2021-22156 — Honeywell "Niagara QNX BadAlloc, Privilege Escalation, and JxBrowser Vulnerabilities" (2021-09-09)	Medium (per Honeywell)	Multiple Niagara Framework/EntSec versions on QNX-based products (JACE line)	BadAlloc-class integer-overflow-in-memory-allocation, QNX privilege escalation, JxBrowser issue bundled in one bulletin	QNX BadAlloc was a wide multi-vendor RTOS memory-allocator flaw family; this bulletin is Tridium's QNX-specific response.
CVE-2023-4863 — Honeywell "Niagara libwebp Vulnerability" (2024-01-09,	6.8 (rescored by Honeywell for Niagara's	Niagara Framework & Enterprise Security, fixed in 4.10u7 / 4.13u2	Heap buffer overflow in libwebp, reached via the jxBrowser component in Niagara's web UI	Upstream libwebp CVE is in CISA's KEV catalog; this is the Niagara-specific downstream patch confirmation. Delta Controls (a separate BAS

CVE / Advisory	CVSS	Product	Vector	Notes
bulletin SB 2024-Tridium-1 / PSIRT-942)	usage context)			vendor on the same Niagara base) issued a matching bulletin, underscoring how many building-automation brands white-label this same framework.
CVE-2025-3936 through CVE-2025-3945 (10 CVEs; Honeywell bulletin hon-corp-niagara-software-vulnerabilities-2025-05-22-01, disclosed by Nozomi Networks Labs, July 2025)	4.1–7.7 (per-CVE; see breakdown below)	Niagara Framework & Enterprise Security ≤4.10u10, ≤4.14u1, ≤4.15	Weak password hash (CWE-916), incorrect file/resource permissions (CWE-732, two instances), argument injection (CWE-88), missing crypto step (CWE-325), NTFS alternate-data-stream handling (CWE-69), observable response discrepancy (CWE-204), improper validation-framework use (CWE-1173), log injection (CWE-117), anti-CSRF token exposed in GET query string (CWE-598)	**Chainable:** CVE-2025-3943 (CSRF token leaked over unencrypted syslog) + CVE-2025-3944 (bad permissions) lets an adjacent attacker who can sniff unencrypted Syslog traffic hijack an admin session and reach root-level code execution on the QNX platform — but only if the site has disabled Niagara's TLS/encryption (which triggers a dashboard warning most sites apparently ignore). Fixed in 4.10u11 / 4.14u2 / 4.15u1.
CVE-2026-11804 (Honeywell bulletin SB 2026-Tridium-1 / PSIRT-1463, 2026-07-02)	5.2	Niagara Framework & Enterprise Security on Windows/Linux/QNX, <4.14.6 and <4.15.5	Improper access control (CWE-280) in the Niagara "program module" — privilege abuse given adjacent-network access and high existing privilege	Most recent confirmed advisory found in this research pass. Fixed in 4.14u6 / 4.15u5, or by applying the patched `program-rt-4.14.5.22.1.jar` / `program-rt-4.15.4.24.1.jar` modules directly.
10 CVEs — Honeywell "Tridium Wi-Fi WPA/2 Protocol Vulnerabilities" (2017-10-16)	High	JACE 8000, JACE 700	KRACK (Key Reinstallation Attack) family against WPA2	Applies specifically to Wi-Fi-equipped JACE units — relevant if any of the census's 480 Tridium devices have a wireless radio rather than pure wired BACnet/IP.

No public CVE found specifically against "Niagara Edge 10" as a standalone product line beyond the framework-wide bulletins above (ICSA-19-262-01 names it, the rest apply by shared codebase). **No CISA ICS advisory found for 2021–2024** under the Tridium/Niagara name in this search pass — Honeywell's own PSIRT bulletin index is the only public record for several of those years' fixes (libwebp, MQTT driver, Hx profile, JNLP/Web Start, log4j/Spring4Shell "no impact" notices) and several of those bulletins carry no CVE number at all — treat "no CVE" as Honeywell's own disclosure choice, not evidence of absence of a real underlying issue.

Top attack vectors (MITRE ATT&CK for ICS)

1. **T0812 Default Credentials + the disabled-account-blank-password bug (CVE-2017-16748).** Niagara ships/ships-shipped with a known pattern of exploitable default or disabled-but-still-authenticating accounts. Combined with the long public history (2012 onward) of operators never changing factory credentials, this is the highest-probability initial-access path for any Tridium device found still running AX or early Niagara 4 builds in the census.

2. **T0888 Remote System Information Discovery via unauthenticated Fox protocol (TCP/1911).** The FBI's December 2018 industry warning (covered contemporaneously by CyberScoop) stated plainly that Niagara's Fox port "discloses system information without authenticating" — version, device identity, and configuration hints are retrievable pre-auth. Tridium's own position was that this is a documented protocol behavior, not a patchable bug, meaning **it will still be true on whatever firmware you eventually pull.** A 2018-era Shodan sweep found ~20,000 exposed Fox endpoints in the US; a 2012-era sweep (Rios/McCorkle) found ~21,000 Niagara systems generally. The lesson for this census: assume every one of the 480 Tridium devices that answers on 1911/4911 is giving away reconnaissance data to anyone who can reach it, full stop.

3. **T0822 External Remote Services.** Niagara/BAS systems have a well-documented history of being placed directly on the internet "for remote facilities management" with no firewall — the 2013 NBC News account of an attacker reaching an office building's controls via a Shodan-found, directly-internet-connected Niagara box is the canonical example, and a more recent survey found 548 internet-exposed BAS devices near US data centers including EOL NiagaraAX 3.x. Given this project's own Niagara Central access gap, it is reasonable to assume ARNG facility operators face the identical "nobody owns patching this" problem that produced those exposures.

4. **T0843 Program Download / T0857 System Firmware via a compromised Niagara Supervisor.** Because Niagara Stations trust each other over Fox for configuration push (Supervisor → JACE), compromising one Supervisor/Station — e.g. via the 2025 Nozomi CSRF+permissions chain once an admin session is hijacked — gives an attacker a legitimate channel to push configuration/program changes to every subordinate JACE it manages, the same "weaponize the management plane, use the vendor's own protocol" pattern documented for FactoryTalk AssetCentre and Control Expert elsewhere in this project's briefs.

5. **T0836 Modify Parameter via BACnet `WriteProperty` from a compromised JACE.** A JACE is a legitimate BACnet client/server to the field devices below it (VAV boxes, chillers, access-control integrations in Niagara-managed security deployments). A compromised JACE can issue in-spec BACnet writes that no BACnet-naive monitoring will flag as abnormal — this is the building-automation analogue of the "compromised HMI issues legitimate protocol writes" pattern already documented for S7comm/CIP/UMAS in the purdue-l2-area-supervisory-brief.md.

Logging / detection matrix

Ordered by detection value per ingest dollar, tailored to what is actually monitorable on Niagara/Fox/BACnet without firmware-level instrumentation (none of this requires the binary this project doesn't yet have — it is

all network- and host-log-observable):

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	**Network IDS (Suricata/Zeek) on Fox (TCP/1911, TLS 4911)**	Unauthenticated Fox handshake / version-query response crossing a non-management VLAN boundary	T0888 recon — the FBI-flagged unauthenticated info disclosure	T0888 Remote System Information Discovery
2	Network IDS	Fox session on port 1911 (cleartext) where 4911 (TLS) is configured/expected on that device class	Sites that silently fell back to unencrypted Fox — the exact misconfiguration the 2025 Nozomi CSRF+permissions chain (CVE-2025-3943/3944) requires	T0885 Commonly Used Port abuse pattern / precondition for CSRF-token-sniff chain
3	**Niagara Station/Platform audit log** (`AuditHistoryExt` , if the device exposes it to syslog)	`login.failure` x N then `login.success` ; login using a disabled/service account name	Brute force success; the CVE-2017-16748 disabled-account-blank-password pattern	T0812 Default Credentials
4	Niagara audit log	`config.change` / program-module install or modification outside a change window	Config/program tamper via a compromised Supervisor session (CVE-2026-11804 program-module privilege-abuse path)	T0843 Program Download
5	**Network IDS**	BACnet/IP `WriteProperty` / `WriteFile` to a JACE's field-side BACnet segment from a host that is not that JACE's own configured peer	Direct field-device parameter tamper, or a compromised JACE being used to tamper peers	T0836 Modify Parameter
6	**Firewall / NetFlow at the OT perimeter**	Any Niagara device (Fox 1911/4911, BACnet/IP 47808, or the web UI port) originating or accepting a connection from a non-RFC1918 address	Internet exposure — the single most-repeated finding in Niagara's public incident history (2012 Shodan sweep, 2013 NBC intrusion, 2018 FBI warning, 2024 548-device BAS survey)	T0822 External Remote Services
7	**Sysmon/EDR on any Windows Niagara Supervisor host**	EventID 7 ImageLoad — non-Tridium DLLs/JARs loaded by the Niagara station process, or jxBrowser/Chromium child processes spawning outside the browser sandbox	Chromium 0-day exploitation (CVE-2019-5786 pattern) or libwebp/jxBrowser exploitation (CVE-2023-4863) via the embedded web UI	T1189 Drive-by Compromise (Enterprise) landing on the Niagara web UI
8	**Web UI access log on the JACE/Supervisor**	Authenticated session followed by a request containing a CSRF token observed in a prior unencrypted GET/log line	The specific CVE-2025-3943 → CVE-2025-3944 chain (token leak over unencrypted syslog, then session hijack)	T0859 Valid Accounts

Secondary:

- Enable and forward Niagara's built-in "Security," "Admin," and "Station" audit categories to SIEM via syslog — but do so over an **encrypted** transport; the 2025 Nozomi chain specifically depends on sites forwarding syslog (including the CSRF token) in the clear.
- Treat any Tridium device in the census answering on TCP/1911 or TCP/4911 at all as a device requiring positive confirmation of patch level before being considered low-risk — there is no way to distinguish a patched 4.15u1 JACE from a vulnerable 4.10u10 one purely from the network banner, since the Fox handshake discloses version info by design (which is itself useful for an *inventory* pass even though it is also the FBI-flagged exposure).
- KRACK/WPA2 exposure (Honeywell's 2017 Wi-Fi bulletin) only applies to wireless-equipped JACE-8000/700 units — confirm in the census whether any of the 480 devices carry a Wi-Fi MAC in addition to/instead of wired Ethernet.
- Subscribe to the Honeywell product-security notification page (honeywell.com/us/en/product-security) directly — Tridium/Niagara advisories are issued under the Honeywell PSIRT umbrella, not a separate Tridium-branded feed, and several (MQTT driver, Hx profile, JNLP/Web Start) never received a CISA ICS advisory or CVE number, so CISA's advisory list alone will under-count this vendor's real patch history.

Specific concerns for this dataset

1. **480 devices, 3rd-largest OT vendor in the census, zero firmware in hand.** This is the largest coverage gap of any vendor this project has written a brief for. At this scale, even a low per-device probability of an unpatched 2012-era credential-storage bug or the 2018-era disabled-account-blank-password bug (CVE-2017-16748) turns into a near-certainty that *some* fraction of the fleet is exploitable with publicly known techniques — Niagara has one of the longest continuously-exploitable-class CVE histories of any vendor in this project (2012 → 2026, fourteen years, at least 30 distinct CVEs/advisories found in this pass), yet the product line is still deployed essentially unchanged in architecture.

2. **The OUI-derived "Tridium, Inc." label almost certainly undercounts the real blast radius.** Niagara is a white-labeled/OEM framework — Delta Controls (confirmed via its own matching libwebp bulletin above) and other BAS brands ship the identical Niagara codebase under their own nameplate and MAC OUI. The census's 480-device figure is a floor for "devices running Niagara," not a ceiling — some devices currently bucketed under other vendor OUIs in this census may also be running Niagara internally.

3. **No firmware acquired means no version ground-truth.** Every CVE table above is version-gated, and this project has no way yet to confirm which of the 480 census devices are on AX (EOL, unpatchable by vendor policy), early Niagara 4.x (CVE-2017-16748-class exposure), or current 4.14/4.15 (only exposed to the newest 2025/2026 findings). Until Niagara Central access is obtained or a device is interrogated directly (even just a Fox banner-grab, accepting the T0888 exposure tradeoff of doing so), **assume worst case: AX or pre-4.10u11 Niagara 4**, given how long these product lines stay in field service in building-automation deployments (10+ year lifecycles are normal for BAS, unlike IT gear).

4. **Fox protocol's unauthenticated info-disclosure is a documented, unfixed, "working as designed" behavior per the vendor.** Unlike the other CVEs in this brief, there is no patch to track for the Fox-recon issue — mitigation is purely network isolation (VPN/ firewall/VLAN segmentation off any internet-reachable or flat-IT-adjacent network), which makes it a pure detection-and-segmentation

problem rather than a patch-management one. Any ARNG facility network design review should treat "is Fox/BACnet reachable from outside the BAS VLAN" as a standing finding independent of patch level.

5. **The 2025 Nozomi chain (CVE-2025-3943/3944) is a real root-RCE path, but it is conditional on a specific misconfiguration (disabled encryption + unencrypted syslog forwarding) that triggers a visible dashboard warning.** This is good news operationally — it means the exploit chain is detectable and preventable through configuration review alone, without waiting on a firmware pull. Recommend this be an explicit configuration check against any Tridium device reachable for interrogation.

Sources

- CISA ICSA-12-228-01A — Tridium Niagara AX Framework Vulnerabilities (Update A)
- CISA ICS-ALERT-12-195-01 — Tridium Niagara Vulnerabilities
- CISA ICSA-13-045-01 — Tridium NiagaraAX Directory Traversal Vulnerability
- CISA ICSA-18-191-03 — Tridium Niagara (CVE-2017-16744, CVE-2017-16748)
- CISA ICSA-18-333-02 — Tridium Niagara Enterprise Security, Niagara AX, and Niagara 4 (CVE-2018-18985)
- CISA ICSA-19-262-01 — Tridium Niagara (CVE-2019-8998, CVE-2019-13528)
- CISA ICSA-20-224-03 — Tridium Niagara (CVE-2020-14483)
- Honeywell Product Security — advisory index (Niagara/Tridium bulletins 2014–2026)
- Honeywell bulletin — Niagara software vulnerabilities, 2025-05-22 (CVE-2025-3936 to -3945)
- Honeywell bulletin — Tridium Program Module Vulnerability, 2026-07-02 (CVE-2026-11804)
- Honeywell bulletin — Niagara libwebp Vulnerability, 2024-01-09 (CVE-2023-4863)
- Nozomi Networks Labs — Critical Vulnerabilities Found in Tridium Niagara Framework (July 2025)
- runZero — Latest Tridium Niagara vulnerabilities (fingerprinting/detection guidance)
- CyberScoop — FBI warns industry that hackers could probe vulnerable connections in building systems (Fox protocol / port 1911, Dec 2018)
- Wikipedia — Tridium (ownership history, 2012 Washington Post coverage, 2025 Nozomi disclosure summary)
- Tenable — Tridium Niagara Improper Authentication (CVE-2017-16748) plugin detail
- NBC News — Hackers Remotely Take Control of Office Building (2013 Shodan-discovered Niagara intrusion)
- MITRE ATT&CK for ICS — T0812 Default Credentials
- MITRE ATT&CK for ICS — T0822 External Remote Services
- MITRE ATT&CK for ICS — T0836 Modify Parameter
- MITRE ATT&CK for ICS — T0843 Program Download
- MITRE ATT&CK for ICS — T0857 System Firmware
- MITRE ATT&CK for ICS — T0859 Valid Accounts
- MITRE ATT&CK for ICS — T0888 Remote System Information Discovery
- MITRE ATT&CK — T1189 Drive-by Compromise (Enterprise, for the Chromium/jxBrowser web-UI vector)
- Internal: purdue-l3-site-operations-brief.md, purdue-l2-area-supervisory-brief.md, eaton-firmware-threat-brief.md (shape template), honeywell-firmware-threat-brief.md (same parent company, Experion PKS line)

---

php2shell (CVE-2026-109618 / CVE-2026-109619) determination - 2026-10-22

php2shell context: this brief's PHP determination was driven by CVE-2026-109618 / CVE-2026-109619 ("php2shell", CVSS 9.2, PHP 5.4+, emergency-patched 2026-10-21). Those two IDs are carried here **as supplied by the requester** - they were not independently corroborated against NVD/MITRE in this pass, and no vendor-specific CVE was invented to pair with them.

Gating re-verified rather than taken on trust, as instructed. `niagara-central.com` returns HTTP 200 with page title `Welcome To Niagara Central` and authentication prompts - a portal landing page, not a public download store. `tridium.com/us/en/support` returns HTTP 404. The Honeywell Niagara OEM tree (`firmware-staging/Honeywell/Niagara/`) was checked and holds **66 directories, 1 file, 28 KB** - scaffolding plus a README only, no firmware artefact. **Access verdict: GATED, confirmed independently.** No registration or credential attempt was made.

PHP finding: UNDETERMINED. No firmware, no filename, no byte count, no SHA256 - by finding, not omission. Niagara is a Java platform (the Niagara Framework runs a JVM on JACE hardware, with station config in `.bog` /XML and a Java-based web UI), which makes a PHP management interface architecturally unlikely. That is reasoning, not verification, and 568 devices - the largest vendor in this fleet - should not be closed out on reasoning alone.

Fastest route to a definitive answer: a live-device HTTP check against one of the 568 JACE units (`X-Powered-By` header, `.php` path handling). This needs no partner credentials and no firmware, and given the fleet size it is the highest-value single check in this batch.

JACE-8000 golden image — acquired and analysed — 2026-10-22

Acquisition route matters here. Tridium's own portal rejected an authenticated request ("customer not found"), so the vendor channel stayed closed. The image was instead found on a **systems integrator's publicly listed file server** (`downloads.onesight.solutions` , an unauthenticated h5ai directory index also carrying Distech, iSMA and Phoenix Contact material). **Provenance is therefore third-party, not vendor-attested** — the filename and internal version string look official, but nothing here proves the image is unmodified. Treat findings as indicative until corroborated against a vendor-supplied copy.

Artefact	Bytes	SHA256 (first 12)
`J8000_SD_Card_Reimage_4.9.1.30.zip`	315,187,596	`5e44f313a70b`
`SD-TRIDIUM-4.9.1.30.imgc`	313,970,996	`3d1d9346c068`
`HDDRawCopy1.10Setup.exe`	788,048	`ba53f3b60933`

VirusTotal did not hold any of it. The image was a 404 before this pass — 4 of the 5 JACE-8000 hashes were new, so this is net-new baseline rather than a re-pull.

Container format (reverse-engineered)

`.imgc` is HDD Raw Copy Tool's image format, and it is **not** a plain raw image — an attempt to carve from the end of the header produces a garbage partition table, which is how the structure was first noticed. Layout:

```
0x0000  4 KB header: Pascal-length strings
        \x11"HDD Raw Copy Tool"  \x04"1.10"  \x13"Mass Storage Device"
        \x04"1.00"  \x0c"212102612040"        <- source device serial
0x1000  chunk stream, two record types:
        'lol!' + u32 next_delta + u32 uncompressed_size + payload   (data)
        'omg!' + u32 16 + u32 65536 + u32 0                         (64 KB of zeros, 16 B total)
```

Walking the chain consumes the file exactly: **218 `lol!` chunks + 1,748 `omg!` sparse markers**, reconstructing roughly **853 MB**. The sparse markers are why a 4 GB card ships as a 300 MB file.

Useful practical note: **vendor strings are readable in the `.imgc` without reconstruction**, so analysis does not require implementing the decompressor.

Platform

Property	Value
Version banner	`# Standard Niagara Golden Image Version:4.9.1.30`
OS	**QNX** — `QNX v1.2b Boot Loader`
Module signing	`META-INF/NIAGARA4.SF` / `NIAGARA4.RSA` (also `NIAGARA1.RSA`)
Crypto library	**BouncyCastle `bcprov-jdk15on-1.52.1.jar`**
Source media	Panasonic microSDHC 4 GB (per the bundled restore document)

QNX matters for detection engineering: JACE-8000 is **not** Linux, so Linux-oriented host telemetry, osquery packs and ELF-centric YARA assumptions do not transfer.

BouncyCastle 1.52 dates to 2015. Its presence is recorded as an **observation, not a finding** — no CVE is asserted. Whether this build is patched, and whether the vulnerable code paths are reachable in Niagara's usage, were not determined. That is a worthwhile follow-up.

Factory credentials present in plaintext

The image carries a factory configuration block, found at **four separate offsets**:

```
facUser=tridium
facPw=niagara
Route=192.168.1.1
Netmask=255.255.255.0
```

Verification note. The raw bytes read `facPw=niagarat`, with the trailing byte ambiguous because the block sits inside a compressed chunk. Rather than assert the literal, the pair was checked against public documentation: `tridium` / `niagara` is the **documented JACE factory platform login** (Forest Rock's knowledge base for JACE-8000, and Schneider's community article for JACE-6/7). The image is consistent with the documented default.

Correct framing — this is not "568 devices have a default password". These are *factory* credentials, and Niagara 4 commissioning requires changing them. The real exposure is any unit still in, or reverted to, factory state. Note also that on JACE-8000 the older Shell Mode credential reset was **removed**: recovery needs a reset key from Tridium via a distributor, which makes a forgotten-credential device more likely to be left at defaults or abandoned.

The check worth running: probe the platform port on known JACE assets for the factory pair, and flag any device whose platform credentials still match. That converts a firmware observation into a fleet finding.

Still available at the same source, not yet pulled

23 Niagara Supervisor builds: **10 Windows** (4.14.0.162 → 4.15.3.28.2), **11 Linux x64** (4.14.2.12 → 4.15.5.22), **2 legacy Vykon AX** (3.8.111.3, 3.8.504). Sizes run 1.0–2.05 GB, so each exceeds VirusTotal's 650 MB submission ceiling **as an archive** — their extracted contents do not, and that is the route to baselining them. Holding a long version run would also enable cross-version diffing of the framework, which is the most useful thing this corpus could do with Niagara.

Edge-10 and JACE-9000 directories at that source are **documentation only** — no firmware.